LABORATORIUM · Analiza i zarządzanie ryzykiem w cyberbezpieczeństwie

Analiza wpływu na działalność (BIA)

Szpital Powiatowy w Garbowie SP ZOZ – studium przypadku

Element	Opis
Przedmiot	Analiza i zarządzanie ryzykiem w cyberbezpieczeństwie
Forma zajęć	Laboratorium, praca w zespołach 3–4-osobowych
Czas	3 spotkania po 2 godziny lekcyjne + praca własna
Podstawa metodyczna	PN-EN ISO 22301:2020 (ISO 22301:2019), pkt 8.2.2 · ISO/TS 22317:2021 · PN-EN ISO/IEC 27001:2023, zabezpieczenia A.5.29 i A.5.30
Rezultat	Rejestr BIA (XLSX) + raport z analizy (DOCX/PDF) + diagram zależności
Prowadzący	dr. Mariusz Skrzypek
Termin oddania	31.10.2026

> **Uwaga.** Szpital Powiatowy w Garbowie jest podmiotem fikcyjnym, stworzonym na potrzeby zajęć. Opis celowo łączy cechy typowe dla polskich szpitali powiatowych. Wszelkie podobieństwo do rzeczywistych podmiotów, osób i zdarzeń jest przypadkowe.

1. Cel laboratorium i efekty uczenia się

Celem laboratorium jest przeprowadzenie analizy wpływu na działalność (ang. *Business Impact Analysis*, BIA) dla szpitala powiatowego. BIA odpowiada na pytanie: **co się stanie, jeżeli dany proces przestanie działać, jak szybko skutki staną się nieakceptowalne i od czego ten proces zależy**. Wyniki BIA są punktem wyjścia do analizy ryzyka, doboru strategii ciągłości działania oraz planów BCP i DRP, a w podmiotach objętych ustawą o krajowym systemie cyberbezpieczeństwa – elementem systemu zarządzania bezpieczeństwem informacji.

Po zakończeniu zajęć student:

- identyfikuje i kategoryzuje procesy realizowane przez podmiot leczniczy oraz wskazuje procesy krytyczne;
- definiuje kryteria i skale oceny wpływu w kilku wymiarach (zdrowie i życie pacjentów, skutki prawne, finansowe, reputacyjne i operacyjne);
- ocenia narastanie skutków przerwy w czasie i na tej podstawie wyznacza MTPD, RTO, RPO oraz MBCO;
- identyfikuje zasoby (aktywa), od których zależą procesy, i sprawdza spójność czasów odtworzenia zasobów z wymaganiami procesów;
- wskazuje pojedyncze punkty awarii (SPOF) i formułuje rekomendacje;
- wiąże wyniki analizy z wymaganiami prawnymi i oczekiwaniami interesariuszy.

1.1. Podstawowe pojęcia

Pojęcie	Znaczenie w tym laboratorium
MTPD	Maksymalny tolerowany okres zakłócenia (*Maximum Tolerable Period of Disruption*) – czas, po którym skutki niedostępności procesu stają się nieakceptowalne dla organizacji.
RTO	Docelowy czas odtworzenia (*Recovery Time Objective*) – czas, w którym proces (lub zasób) musi zostać przywrócony co najmniej do poziomu MBCO. RTO musi być krótszy od MTPD.
RPO	Docelowy punkt odtworzenia (*Recovery Point Objective*) – maksymalna akceptowalna utrata danych, wyrażona jako czas między ostatnią kopią a awarią.
MBCO	Minimalny akceptowalny poziom działania (*Minimum Business Continuity Objective*) – zakres usług, jaki musi być zapewniony w trybie awaryjnym.
Zależność	Zasób, bez którego proces nie może być realizowany (ludzie, informacje, systemy, infrastruktura, dostawcy, lokalizacje).
SPOF	Pojedynczy punkt awarii – zasób bez rozwiązania alternatywnego, którego utrata zatrzymuje jeden lub wiele procesów.

> **Zasada spójności.** RTO zasobu wspierającego proces nie może być dłuższy niż RTO procesu. Jeżeli proces SOR musi wznowić pracę w trybie elektronicznym w ciągu 2 godzin, a odtworzenie serwera, na którym działa system szpitalny, trwa 8 godzin, to mamy lukę, którą trzeba wykazać w raporcie.

2. Opis organizacji

Szpital Powiatowy w Garbowie Samodzielny Publiczny Zakład Opieki Zdrowotnej jest podmiotem leczniczym niebędącym przedsiębiorcą. Organem tworzącym jest powiat. Szpital zabezpiecza ok. 95 tys. mieszkańców kilku gmin i jest jedynym szpitalem z SOR w promieniu ok. 35 km. W pobliżu przebiega droga ekspresowa, przez co SOR regularnie przyjmuje ofiary wypadków komunikacyjnych. Szpital ma umowę z Narodowym Funduszem Zdrowia w ramach systemu podstawowego szpitalnego zabezpieczenia świadczeń (sieci szpitali) na poziomie I stopnia.

Szpital zatrudnia ok. 520 osób (w tym ok. 90 lekarzy na umowach o pracę i kontraktach, ok. 230 pielęgniarek i położnych) i dysponuje 186 łóżkami. Ze względu na sektor i wielkość jest **podmiotem kluczowym** w rozumieniu znowelizowanej ustawy o krajowym systemie cyberbezpieczeństwa.

2.1. Struktura i lokalizacje

Budynek	Funkcje
A (główny)	SOR z izbą przyjęć, blok operacyjny (3 sale), Oddział Anestezjologii i Intensywnej Terapii (6 łóżek), Oddział Chirurgii Ogólnej, Oddział Chorób Wewnętrznych, pracownia RTG i TK, laboratorium, bank krwi. W piwnicy: serwerownia główna, rozdzielnia elektryczna, kotłownia gazowa, centralna sterylizatornia.
B	Oddział Ginekologiczno-Położniczy z salą porodową, Oddział Neonatologiczny, Oddział Pediatryczny, pracownia USG, apteka szpitalna.
C (administracyjny)	Dyrekcja, księgowość, kadry i płace, dział rozliczeń z NFZ, dział zamówień publicznych, Dział Informatyki, pomieszczenie z zapasowym urządzeniem do kopii zapasowych.
D (ambulatoryjny)	Poradnie specjalistyczne (chirurgiczna, ginekologiczna, kardiologiczna, diabetologiczna, pediatryczna), rejestracja centralna, nocna i świąteczna opieka zdrowotna.
Teren szpitala	Lądowisko dla śmigłowców LPR, zbiornik ciekłego tlenu, agregat prądotwórczy, magazyn odpadów medycznych, garaże transportu sanitarnego.

Szpital korzysta z usług zewnętrznych: żywienie pacjentów (firma cateringowa dowożąca posiłki z kuchni w innej miejscowości), pranie bielizny szpitalnej, odbiór i unieszkodliwianie odpadów medycznych, ochrona fizyczna, część badań laboratoryjnych specjalistycznych (laboratorium referencyjne w Lublinie), opisy badań TK w godzinach nocnych (teleradiologia).

3. Główne procesy realizowane w szpitalu

Poniższa lista jest **punktem wyjścia, a nie zamkniętym katalogiem**. Zespół może procesy łączyć, dzielić lub dodawać, ale każdą zmianę musi uzasadnić w raporcie. Zwróćcie uwagę, że ten sam proces może mieć różną krytyczność w zależności od trybu (np. zabieg nagły i zabieg planowy) – rozważcie, czy nie należy ich rozdzielić.

Id	Kategoria	Proces i jego zakres
P01	Kliniczny	**Przyjęcie i leczenie w trybie nagłym (SOR)** – segregacja medyczna (triaż), diagnostyka wstępna, stabilizacja, decyzja o hospitalizacji lub przekazaniu do innego szpitala; współpraca z zespołami ratownictwa medycznego i LPR.

Id	Kategoria	Proces i jego zakres
P02	Kliniczny	**Przyjęcia planowe** – kwalifikacja, kolejka oczekujących, przyjęcie na oddział, założenie dokumentacji.
P03	Kliniczny	**Leczenie na oddziałach łóżkowych** – zlecenia lekarskie, podawanie leków, obserwacja, dokumentacja bieżąca, wypis.
P04	Kliniczny	**Zabiegi operacyjne i anestezja** – planowanie bloku, przygotowanie pacjenta, zabieg, opieka pooperacyjna.
P05	Kliniczny	**Intensywna terapia** – ciągłe monitorowanie i podtrzymywanie funkcji życiowych.
P06	Kliniczny	**Opieka okołoporodowa i neonatologiczna** – porody, cięcia cesarskie, opieka nad noworodkiem, badania przesiewowe.
P07	Diagnostyczny	**Diagnostyka laboratoryjna** – pobranie i identyfikacja materiału, wykonanie badań, autoryzacja i przekazanie wyników; współpraca z laboratorium zewnętrznym.
P08	Diagnostyczny	**Diagnostyka obrazowa** – badania RTG, TK, USG, opis badań (w nocy – teleradiologia), archiwizacja obrazów.
P09	Kliniczny	**Gospodarka krwią** – zamawianie krwi, próby zgodności, przechowywanie i wydawanie, dokumentowanie przetoczeń.
P10	Wspierający medyczny	**Zaopatrzenie farmaceutyczne** – zamawianie, przechowywanie i wydawanie leków i wyrobów medycznych na oddziały.
P11	Wspierający medyczny	**Sterylizacja** – dekontaminacja i sterylizacja narzędzi chirurgicznych, dokumentacja procesu.
P12	Wspierający medyczny	**Żywienie pacjentów** – zamawianie diet, dostawy posiłków (outsourcing).
P13	Kliniczny	**Ambulatoryjna opieka specjalistyczna i NiŚOZ** – rejestracja, wizyty, porady, e-recepty i e-skierowania.
P14	Kliniczny	**Transport sanitarny** – przewozy międzyszpitalne i na badania poza szpitalem.
P15	Administracyjny	**Prowadzenie i udostępnianie dokumentacji medycznej** – EDM, raportowanie zdarzeń medycznych, udostępnianie dokumentacji pacjentom i uprawnionym podmiotom.
P16	Administracyjny	**Rejestracja i weryfikacja uprawnień pacjentów** – e-rejestracja, weryfikacja ubezpieczenia, obsługa kolejek oczekujących.
P17	Finansowy	**Sprawozdawczość i rozliczanie świadczeń z NFZ** – comiesięczne sprawozdania, korekty, rozliczenia ryczałtu sieciowego.
P18	Administracyjny	**Kadry, płace i grafiki dyżurów** – ewidencja czasu pracy, wynagrodzenia, planowanie obsady.
P19	Finansowy	**Finanse, księgowość i zamówienia publiczne** – płatności, sprawozdawczość finansowa, postępowania przetargowe.
P20	Techniczny	**Utrzymanie infrastruktury technicznej** – zasilanie podstawowe i awaryjne, gazy medyczne, ogrzewanie, wentylacja i klimatyzacja, windy.
P21	Techniczny	**Utrzymanie systemów IT i obsługa incydentów** – administracja systemami, kopie zapasowe, wsparcie użytkowników, obsługa i zgłaszanie incydentów.
P22	Zarządczy	**Komunikacja wewnętrzna i zewnętrzna** – telefonia, przywoływanie personelu, łączność z dyspozytornią medyczną, informowanie pacjentów i mediów.

Id	Kategoria	Proces i jego zakres
P23	Zarządczy	**Zarządzanie kryzysowe** – plany na wypadek zdarzeń masowych, ewakuacji, epidemii; współpraca z organami administracji.

4. Zasoby (aktywa), od których zależą procesy

W analizie BIA zasoby grupujemy w kategorie. Dla każdego procesu krytycznego należy ustalić, z których zasobów korzysta, czy istnieje dla nich rozwiązanie alternatywne i jak długo proces może działać bez danego zasobu. **Nie wszystkie zależności opisano wprost** – część wynika z załączników A–C, a część wymaga własnego rozumowania (np. czym kończy się awaria sieci dla telefonii, która działa w technologii VoIP).

Kategoria zasobu	Zasoby w Szpitalu w Garbowie
Ludzie i kompetencje	Lekarze specjaliści (w tym anestezjolodzy – ograniczona liczba), pielęgniarki i położne, diagności laboratoryjni, technicy elektroradiologii, farmaceuci, Dział Informatyki (4 osoby), dział techniczny, pracownicy rejestracji i rozliczeń; osoby z unikalną wiedzą (np. jedyna osoba znająca konfigurację interfejsów systemu laboratoryjnego).
Informacje	Elektroniczna i papierowa dokumentacja medyczna, wyniki badań i obrazy diagnostyczne, księgi i rejestry (np. przetoczeń, zabiegów, porodów), zlecenia lekarskie, dane do sprawozdań NFZ, dane kadrowo-płacowe, procedury i plany awaryjne, dane dostępowe i konfiguracje systemów.
Systemy aplikacyjne	System szpitalny (HIS) z modułami ruchu chorych, oddziałowym, zleceń i EDM; system laboratoryjny (LIS); system radiologiczny (RIS) z archiwum obrazów (PACS); system apteczny; system bankowy krwi; system finansowo-księgowy, kadrowo-płacowy i magazynowy (ERP); e-rejestracja; poczta elektroniczna; usługa katalogowa i uwierzytelnianie użytkowników.
Infrastruktura IT	Serwerownia główna (serwery, macierz, przełączniki rdzeniowe, zapora sieciowa), urządzenie do kopii zapasowych w budynku C, sieć LAN łącząca cztery budynki, sieć Wi-Fi, stacje robocze i drukarki (w tym drukarki opasek i etykiet), łącze internetowe, centrala telefoniczna VoIP.
Usługi zewnętrzne i systemy krajowe	Platforma P1 (e-recepta, e-skierowanie, raportowanie zdarzeń medycznych, wymiana EDM), weryfikacja ubezpieczenia (eWUŚ), portale NFZ do sprawozdawczości, dostawcy systemów (wsparcie serwisowe), teleradiologia, laboratorium referencyjne, operator telekomunikacyjny.
Infrastruktura techniczna i media	Zasilanie z sieci, agregat prądotwórczy, zasilacze UPS, instalacja gazów medycznych i zbiornik tlenu, ogrzewanie, wentylacja i klimatyzacja (w tym blok operacyjny i serwerownia), woda, windy.
Aparatura medyczna	Analizatory laboratoryjne, tomograf, aparaty RTG i USG, respiratory, kardiomonitory, centrala monitorowania na OAiIT, sterylizatory, lodówki do krwi i leków z monitoringiem temperatury.
Dostawcy fizyczni	Dostawcy leków i wyrobów medycznych, catering, pralnia, odbiór odpadów, dostawca tlenu, dostawca paliwa do agregatu, RCKiK (krew).
Lokalizacje	Budynki A–D, serwerownia w piwnicy budynku A, lądowisko, możliwe miejsca pracy zastępczej.

> **Wskazówka.** Szukajcie zależności łańcuchowych. Przykład: proces P07 zależy od systemu LIS, LIS zależy od serwera i sieci, serwer od zasilania i klimatyzacji serwerowni, a przekazanie wyniku do oddziału – od interfejsu z HIS. Awaria na końcu łańcucha zatrzymuje cały proces, nawet jeżeli analizatory działają poprawnie.

5. Główne wymagania prawne

Wymagania prawne wpływają na BIA na dwa sposoby: określają **skutki** niedotrzymania obowiązków (kategoria wpływu prawnego i regulacyjnego) oraz narzucają **terminy**, które ograniczają MTPD (np. czas na zgłoszenie incydentu albo termin sprawozdania). W tabeli podano publikację pierwotną aktu. **Zadaniem zespołu jest ustalenie aktualnego tekstu jednolitego w systemie ISAP** i wskazanie konkretnych przepisów istotnych dla analizy.

Akt prawny / norma	Publikacja	Znaczenie dla BIA
Ustawa z dnia 5 lipca 2018 r. o krajowym systemie cyberbezpieczeństwa	Dz. U. z 2018 r. poz. 1560; nowelizacja: Dz. U. z 2026 r. poz. 252	Obowiązek SZBI, zarządzania ryzykiem i ciągłością działania, terminy zgłaszania incydentów poważnych do CSIRT, odpowiedzialność kierownika podmiotu.
Dyrektywa (UE) 2022/2555 (NIS2)	Dz. Urz. UE L 333 z 27.12.2022	Ciągłość działania, zarządzanie kryzysowe, kopie zapasowe i odtwarzanie jako obowiązkowe środki zarządzania ryzykiem.
Ustawa z dnia 15 kwietnia 2011 r. o działalności leczniczej	Dz. U. z 2011 r. nr 112 poz. 654	Warunki udzielania świadczeń, obowiązek udzielenia pomocy w stanie nagłym, wymagania wobec pomieszczeń i urządzeń.
Ustawa z dnia 6 listopada 2008 r. o prawach pacjenta i Rzeczniku Praw Pacjenta	Dz. U. z 2009 r. nr 52 poz. 417	Prawo do świadczeń, do dokumentacji medycznej i jej udostępnienia, do informacji.
Ustawa z dnia 28 kwietnia 2011 r. o systemie informacji w ochronie zdrowia	Dz. U. z 2011 r. nr 113 poz. 657	EDM, obowiązki raportowania zdarzeń medycznych i wymiany dokumentacji przez P1.
Rozporządzenie MZ z dnia 6 kwietnia 2020 r. w sprawie rodzajów, zakresu i wzorów dokumentacji medycznej oraz sposobu jej przetwarzania	Dz. U. z 2020 r. poz. 666	Wymagania dla dokumentacji elektronicznej, w tym jej dostępności, integralności i kopii.
Ustawa z dnia 8 września 2006 r. o Państwowym Ratownictwie Medycznym	Dz. U. z 2006 r. nr 191 poz. 1410	Zadania SOR, gotowość do przyjęcia pacjentów, współpraca z dyspozytorami.
Ustawa z dnia 27 sierpnia 2004 r. o świadczeniach opieki zdrowotnej finansowanych ze środków publicznych	Dz. U. z 2004 r. nr 210 poz. 2135	Sieć szpitali, umowa z NFZ, sprawozdawczość, kolejki oczekujących, weryfikacja uprawnień.
Rozporządzenie (UE) 2016/679 (RODO) oraz ustawa z dnia 10 maja 2018 r. o ochronie danych osobowych	Dz. Urz. UE L 119 z 4.05.2016; Dz. U. z 2018 r. poz. 1000	Dostępność danych i zdolność do ich szybkiego przywrócenia (art. 32 RODO), zgłaszanie naruszeń w 72 godziny.

Akt prawny / norma	Publikacja	Znaczenie dla BIA
Rozporządzenie RM z dnia 21 maja 2024 r. w sprawie Krajowych Ram Interoperacyjności…	Dz. U. z 2024 r. poz. 773	Wymagania dla systemu zarządzania bezpieczeństwem informacji w systemach teleinformatycznych podmiotów publicznych.
Ustawa z dnia 15 września 2022 r. o medycynie laboratoryjnej	Dz. U. z 2022 r. poz. 2280	Wymagania dla medycznego laboratorium diagnostycznego, w tym dokumentowania badań.
Ustawa z dnia 22 sierpnia 1997 r. o publicznej służbie krwi	Dz. U. z 1997 r. nr 106 poz. 681	Gospodarka krwią w podmiocie leczniczym, identyfikowalność.
Ustawa z dnia 26 kwietnia 2007 r. o zarządzaniu kryzysowym; ustawa z dnia 5 grudnia 2024 r. o ochronie ludności i obronie cywilnej	Dz. U. z 2007 r. nr 89 poz. 590; Dz. U. z 2024 r. poz. 1907	Rola szpitala w planach zarządzania kryzysowego i ochrony ludności.
Ustawa z dnia 29 września 1994 r. o rachunkowości	Dz. U. z 1994 r. nr 121 poz. 591	Terminy sprawozdawcze, ochrona i przechowywanie ksiąg rachunkowych.
PN-EN ISO 22301:2020, ISO/TS 22317:2021, PN-EN ISO/IEC 27001:2023	Normy	Metodyka BIA, wymagania ciągłości działania i gotowości ICT.

6. Interesariusze i ich oczekiwania

Oczekiwania interesariuszy pomagają określić, które skutki są dla szpitala nieakceptowalne i jak szybko. Zespół powinien uzupełnić listę o interesariuszy, których brakuje, oraz wskazać, z którymi procesami wiąże się każde oczekiwanie.

Interesariusz	Główne oczekiwania
Pacjenci i ich rodziny	Bezpieczne i nieprzerwane leczenie, dostęp do wyników i dokumentacji, poufność danych, rzetelna informacja w sytuacji awarii.
Personel medyczny	Dostęp do aktualnych informacji o pacjencie i wyników badań, jasne procedury pracy awaryjnej, sprawna aparatura, bezpieczeństwo pracy.
Organ tworzący (powiat)	Ciągłość świadczeń dla mieszkańców, stabilność finansowa, brak zdarzeń naruszających reputację, zgodność z prawem.
Narodowy Fundusz Zdrowia (oddział wojewódzki)	Realizacja umowy, terminowa i poprawna sprawozdawczość, dostępność świadczeń, prowadzenie list oczekujących.
Wojewoda i dysponenci ratownictwa medycznego	Gotowość SOR do przyjmowania pacjentów, informowanie o czasowej niezdolności do przyjęć, udział w zdarzeniach masowych.
Organ właściwy ds. cyberbezpieczeństwa i CSIRT sektorowy	Spełnianie obowiązków podmiotu kluczowego, terminowe zgłaszanie incydentów, współpraca przy ich obsłudze.
Prezes UODO	Ochrona danych osobowych, zgłaszanie naruszeń, zdolność przywracania dostępności danych.
Centrum e-Zdrowia	Raportowanie zdarzeń medycznych i wymiana EDM przez P1, wystawianie e-recept i e-skierowań.

Interesariusz	Główne oczekiwania
Dostawcy systemów i usług	Jasne wymagania serwisowe, dostęp zdalny na uzgodnionych zasadach, terminowe płatności.
Sąsiednie szpitale	Uzgodnione zasady przekazywania pacjentów w czasie niedostępności oddziałów lub SOR.
Państwowa Inspekcja Sanitarna	Przestrzeganie wymagań sanitarnych, w tym sterylizacji, żywienia i gospodarki odpadami.
Media i społeczność lokalna	Rzetelna i szybka informacja o utrudnieniach w działaniu szpitala.

7. Materiały źródłowe

Poniższe materiały zawierają informacje potrzebne do oszacowania tolerancji czasowej procesów, wymagań dotyczących utraty danych oraz rzeczywistych czasów odtworzenia zasobów. Część danych jest niepełna lub niespójna – w takim przypadku przyjmijcie założenie i opiszcie je w raporcie.

Załącznik A. Notatka z rozmowy z Kierownikiem Działu Informatyki

„Główna serwerownia jest w piwnicy budynku A, za ścianą kotłowni. Mamy tam dwa serwery wirtualizacji, jedną macierz i dwa przełączniki rdzeniowe. System szpitalny, apteczny, ERP i poczta działają na wirtualizacji. Laboratorium ma swój własny serwer fizyczny – ma już dziewięć lat, dostawca systemu nie chciał migracji, bo musiałby ponownie zestawiać interfejsy do analizatorów. Interfejsy zna tylko kolega Piotr.

Kopia pełna robi się co noc o 23:00 na urządzenie w budynku C. Dla bazy systemu szpitalnego dodatkowo co cztery godziny kopiujemy logi transakcyjne. Raz w tygodniu wynosimy kopię na taśmie do sejfu w dyrekcji, ale szczerze mówiąc, odtworzenia z taśmy nie próbowaliśmy od dwóch lat. Przywrócenie całego środowiska z kopii szacuję na jakieś 10–12 godzin, o ile mamy na czym je uruchomić.

Internet mamy z jednego operatora, światłowodem. Jest modem LTE, ale tylko dla jednego komputera w rejestracji. Telefony wewnętrzne są na VoIP, więc jak padnie sieć, to i telefony. Kontrolery domeny są dwa, oba w tej samej serwerowni. Obrazy z TK i RTG trzymamy lokalnie przez 18 miesięcy, starsze są w archiwum u dostawcy usługi w chmurze.

Pracujemy w dni robocze od 7:00 do 15:00. Po godzinach jest telefon do mnie albo do zastępcy, ale nie mamy formalnych dyżurów. Umowa z dostawcą systemu szpitalnego daje nam reakcję w ciągu 4 godzin roboczych.”

Załącznik B. Fragment raportu ze zdarzenia z dnia 11 marca 2025 r.

O godz. 2:40 nastąpił zanik zasilania z sieci w całym szpitalu. Agregat uruchomił się po ok. 40 sekundach i przejął zasilanie obwodów rezerwowanych. Okazało się, że jeden z przełączników rdzeniowych oraz klimatyzacja serwerowni nie były podłączone do obwodu rezerwowanego. Zasilacz UPS w serwerowni podtrzymał pracę przez 22 minuty, po czym serwery wyłączyły się bez kontroli. Zasilanie z sieci wróciło o 4:10, ale system szpitalny był dostępny dopiero o 6:20 z powodu uszkodzenia plików bazy, które naprawiał zdalnie dostawca.

W tym czasie SOR przeszedł na dokumentację papierową. Formularzy papierowych wystarczyło do ok. 5:30; kolejne kopiowano w sekretariacie. Laboratorium wykonywało badania, ale wyniki przekazywano telefonicznie i na wydrukach, a czas oczekiwania na wynik pilny wydłużył się z ok. 40 do ok. 90 minut. Ponieważ telefony wewnętrzne nie działały, pielęgniarki biegały z wynikami między budynkami. O 4:30 lekarz kierujący SOR poprosił dyspozytora medycznego o czasowe kierowanie karetek do Lublina.

Wprowadzenie danych z dokumentacji papierowej do systemu zajęło dwa dni. Dane wprowadzone do systemu między 23:00 a 2:40 (przyjęcia, zlecenia) trzeba było odtworzyć z notatek personelu, ponieważ ostatnie logi transakcyjne skopiowano o 23:00. Nie stwierdzono szkody u pacjentów. Zdarzenie nie zostało zgłoszone jako incydent.

Załącznik C. Fragment wywiadu z Zastępcą Dyrektora ds. Medycznych

„Bez wyników laboratoryjnych blok operacyjny w przypadku nagłym wytrzyma może pół godziny, potem operujemy na ślepo albo przekazujemy pacjenta. Zabiegi planowe przy awarii po prostu przesuwamy – dzień, dwa, to jest do przyjęcia, tydzień już nie, bo pacjenci onkologiczni nie mogą tyle czekać.

Intensywna terapia – tam liczą się zasilanie, tlen i monitory. System szpitalny jest dla nich mniej ważny niż prąd. Tlen mamy w zbiorniku, dostawa co mniej więcej 10 dni; w zeszłym roku cysterna spóźniła się trzy dni przez śnieżycę i było nerwowo.

Apteka – oddziały mają zapas leków na około trzy doby. Ale jak nie ma systemu, to apteka nie wie, co gdzie jest, i robi się bałagan po pierwszym dniu. Sterylizacja: narzędzi wystarczy nam na mniej więcej jeden dzień planowych zabiegów; potem mamy umowę ze szpitalem w Lublinie, ale nikt jej nigdy nie sprawdził w praktyce.

Rozliczenia z NFZ? To nie jest kwestia godzin, ale jeśli nie wyślemy sprawozdania za miesiąc w terminie, to na pieniądze czekamy dłużej, a pensje płacimy do dziesiątego. Bardziej boję się sytuacji, w której stracimy dane z dokumentacji – tego nie da się odrobić. Dzień danych z SOR to kilkudziesięciu pacjentów.”

8. Zadania do wykonania

Zadanie 1. Kontekst i zakres analizy

Opiszcie zakres BIA (które procesy, lokalizacje i okres analizy), przyjęte założenia oraz źródła informacji. Zweryfikujcie listę procesów z rozdziału 3 i uzasadnijcie ewentualne zmiany. Każdemu procesowi przypiszcie właściciela (funkcję, nie nazwisko).

Zadanie 2. Kryteria oceny wpływu

Zdefiniujcie skalę wpływu 1–5 dla co najmniej pięciu kategorii: zdrowie i życie pacjentów, skutki prawne i regulacyjne, skutki finansowe, reputacja, zdolność operacyjna. Każdy poziom skali musi mieć opis pozwalający na powtarzalną ocenę (np. dla kategorii finansowej – przedziały kwot, dla kategorii zdrowotnej – opis skutków). Ustalcie, który poziom wpływu uznajecie za nieakceptowalny.

Zadanie 3. Ocena wpływu w funkcji czasu

Dla każdego procesu oceńcie wpływ w każdej kategorii po upływie: **1 godziny, 4 godzin, 24 godzin, 72 godzin i 7 dni** niedostępności. Wykorzystajcie informacje z załączników B i C. Wskażcie, gdzie ocena jest szacunkiem zespołu, a gdzie wynika z materiałów źródłowych.

Zadanie 4. Parametry ciągłości działania

Na podstawie oceny wpływu wyznaczcie dla każdego procesu MTPD, RTO, RPO i MBCO. Opiszcie, jak proces może działać w trybie awaryjnym (np. dokumentacja papierowa) i jak długo taki tryb da się utrzymać. Na tej podstawie zaproponujcie kolejność odtwarzania procesów.

Zadanie 5. Analiza zależności

Dla procesów krytycznych (co najmniej ośmiu) przygotujcie mapę zależności od zasobów w kategoriach z rozdziału 4. Dla każdego zasobu określcie wymagane RTO i RPO (wynikające z procesów, które od niego zależą), a następnie porównajcie je z możliwościami opisanymi w załączniku A. Wskażcie luki.

Zadanie 6. Pojedyncze punkty awarii

Zidentyfikujcie co najmniej sześć SPOF – technicznych, organizacyjnych i związanych z dostawcami. Dla każdego wskażcie procesy, których dotyczy, i zaproponujcie działanie usuwające lub ograniczające problem.

Zadanie 7. Wymagania prawne i interesariusze

Powiążcie wymagania prawne i oczekiwania interesariuszy z procesami. Wskażcie, które z nich wprost ograniczają MTPD lub RPO. Odpowiedzcie na pytanie, czy zdarzenie z 11 marca 2025 r. należało zgłosić i komu – uzasadnijcie odpowiedź, wskazując przepisy.

Zadanie 8. Wnioski i rekomendacje

Sformułujcie rekomendacje dla dyrekcji szpitala, uszeregowane według priorytetu. Rekomendacja musi wskazywać problem, jego skutek dla procesów i proponowane działanie.

9. Zawartość plików wynikowych

9.1. Rejestr BIA (plik XLSX)

Arkusz	Zawartość
0_Metryka	Nazwa podmiotu, skład zespołu, data, wersja, zakres analizy, lista założeń.
1*Kryteria*wpływu	Kategorie wpływu i opis poziomów skali 1–5, próg nieakceptowalności.
2*Rejestr*procesów	Id, nazwa, kategoria, opis, właściciel procesu, tryb pracy (24/7, dni robocze), krótkie uzasadnienie krytyczności.
3*Ocena*wpływu	Macierz: proces × kategoria wpływu × przedział czasu (1 h, 4 h, 24 h, 72 h, 7 dni), z formatowaniem warunkowym; kolumna ze źródłem oceny.
4*Parametry*ciągłości	MTPD, RTO, RPO, MBCO, opis trybu awaryjnego, maksymalny czas jego utrzymania, priorytet odtwarzania.
5*Rejestr*zasobów	Id zasobu, kategoria, nazwa (opis funkcjonalny), właściciel, lokalizacja, rozwiązanie alternatywne, wymagane RTO/RPO, deklarowane możliwości odtworzenia.
6_Zależności	Macierz proces × zasób (zależność krytyczna / wspierająca / brak), z możliwością filtrowania.
7*Luki*_SPOF	Opis luki lub SPOF, procesy, których dotyczy, różnica między wymaganym a możliwym czasem odtworzenia, rekomendacja, priorytet.
8*Wymagania*prawne	Akt, aktualny tekst jednolity, przepis, wymaganie, procesy, wpływ na parametry ciągłości.
9_Interesariusze	Interesariusz, oczekiwanie, procesy, sposób komunikacji w czasie zakłócenia.

9.2. Raport z analizy (DOCX lub PDF, 8–10 stron)

1. Streszczenie dla dyrekcji (maksymalnie jedna strona): najważniejsze procesy, największe luki, pięć najważniejszych rekomendacji.
2. Zakres, metodyka i założenia analizy.
3. Kryteria oceny wpływu.
4. Wyniki: lista procesów krytycznych z parametrami MTPD, RTO, RPO, MBCO oraz kolejność odtwarzania.
5. Analiza zależności z diagramem dla co najmniej jednego procesu krytycznego (np. SOR lub diagnostyka laboratoryjna).
6. Luki i pojedyncze punkty awarii.
7. Wymagania prawne i oczekiwania interesariuszy – wnioski dla ciągłości działania.
8. Rekomendacje uszeregowane według priorytetu.
9. Ograniczenia analizy i propozycje dalszych prac (np. analiza ryzyka, testy planów).

> **Neutralność technologiczna.** W rejestrze i raporcie opisujcie zasoby według funkcji (np. „system laboratoryjny”, „urządzenie do kopii zapasowych”), bez nazw producentów i produktów. Rekomendacje mają wskazywać wymagane możliwości, a nie konkretne rozwiązania rynkowe.

Pytania kontrolne

1. Dlaczego RTO procesu intensywnej terapii może zależeć bardziej od infrastruktury technicznej niż od systemu szpitalnego?
2. Jakie RPO wynika dla bazy systemu szpitalnego z obecnego harmonogramu kopii i czy jest ono akceptowalne?
3. Czy dwa kontrolery domeny w jednej serwerowni zapewniają ciągłość działania? Uzasadnij.
4. Jak niedostępność łącza internetowego wpływa na procesy, które formalnie nie korzystają z internetu?
5. Dlaczego kopia, której odtworzenia nie przetestowano, nie powinna być traktowana jako zabezpieczenie?
6. Które wnioski z BIA powinny trafić do analizy ryzyka, a które bezpośrednio do planu ciągłości działania?